

معاونت علمی، فناوری و اقتصاد دانش بنیان ریاست جمهوری
ستاد توسعه علوم و فناوری افتا

هسته امنیت شبکه، ارتباطات ثابت، سیار و مراکز داده

عنوان گزارش

**گزارش ارزیابی امنیتی داشبورد دبیرخانه ستاد توسعه علوم و
فناوری امنیت سایبری (asanet.isti.ir)**

مرکز تخصصی آپا دانشگاه محقق اردبیلی

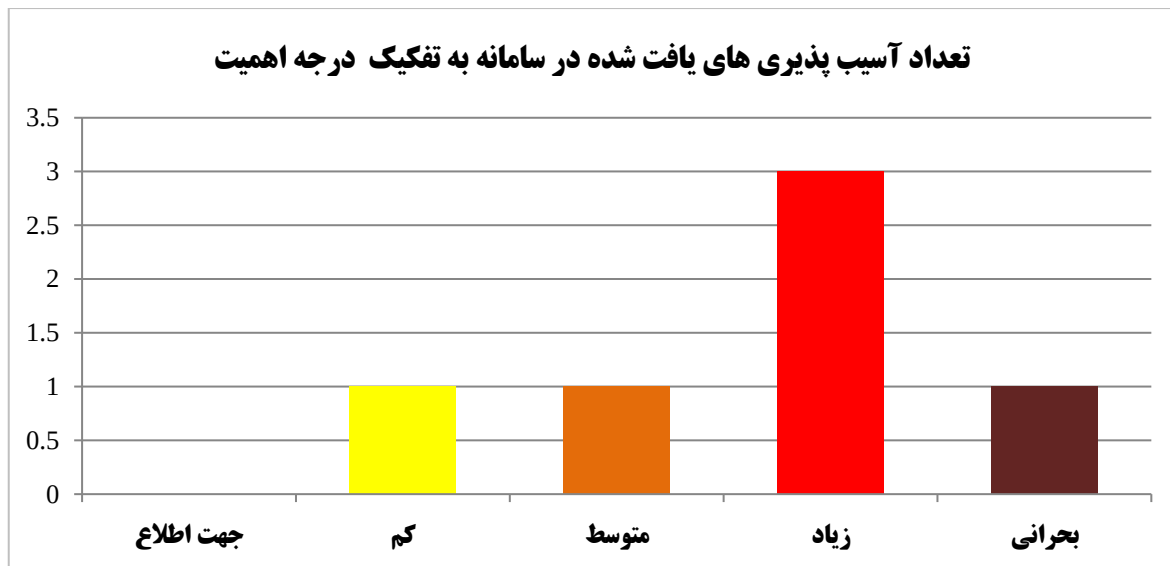
(محرمانه)

تیر ماه ۱۴۰۵



۱	چکیده مدیریتی	۱
۲	مقدمه	۱
2-1	محدوده	۱
۲-۲	محدودیت ها	۲
۳	موارد بررسی شده	۲
۴	تشریح آسیب پذیری ها	۳
۴-۱	افشای نسخه PHP	۳
۴-۱-۱	روش برطرف سازی	۴
۴-۲	عدم تنظیم ویژگی امنیتی SameSite برای کوکی های نشست	۴
۴-۲-۱	روش برطرف سازی	۵
4-3	نقص در کنترل دسترسی (IDOR / Broken Access Control)	۵
۴-۳-۱	روش برطرف سازی	۶
4-4	حمله Brute Force در فرآیند احراز هویت	۷
۴-۴-۱	روش برطرف سازی	۸
4-5	Cross-Site Scripting از نوع Reflected	۸
۴-۵-۱	روش برطرف سازی	۹
4-6	تزریق SQL در پارامتر photos[]	۹
۴-۶-۱	روش برطرف سازی	۱۰
۵	اطلاعات تماس تیم تست	۱۱

۱ چکیده مدیریتی



۲ مقدمه

سند پیش رو، گزارش آزمون نفوذپذیری "دانشبورد دبیرخانه ستاد توسعه علوم و فناوری امنیت سایبری" به نشانی <https://asanet.isti.ir> است که با هدف شناسایی آسیب پذیری ها و نقاط ضعف امنیتی سامانه مذکور صورت گرفته است..

۲-۱ محدوده

آدرس سامانه:

<https://asanet.isti.ir/>

نوع آزمون : جعبه خاکستری

حساب های کاربری: کاربر با نام کاربری jamali

محدوده زمانی تست: ۲۲ الی ۳۱ تیر

۲-۲ محدودیت ها

وبسایت هدف در حین فرایند ارزیابی در دسترس کاربران و عموم می باشد و هیچ دسترسی خاصی تعریف نشده است.

۳ موارد بررسی شده

ردیف	عنوان آسیب پذیری	وجود آسیب پذیری در سامانه هدف		
		بله	خیر	بررسی نشده
۱	شناسایی نام و نسخه پلتفرم	☒	☐	☐
۲	نشت اطلاعات در کد منبع، هدر http، پیامهای خطا و ...	☐	☒	☐
۳	نمایش محتوای پوشه ها	☐	☒	☐
۴	نمایش صفحه ورود واسط مدیریتی سامانه	☒	☐	☐
۵	عدم استفاده از هدرهای امنیتی http	☐	☒	☐
۶	فعال بودن متدهای غیرمجاز http	☐	☒	☐
۷	دسترسی به فایل های قدیمی، حساس و پشتیبان	☐	☒	☐
۸	استفاده از اعتبارنامه های پیش فرض	☐	☒	☐
۹	فقدان یا ضعف مکانیزم مسدود سازی حساب کاربری	☒	☐	☐
۱۰	دور زدن مکانیزم احراز هویت	☒	☐	☐
۱۱	فقدان یا ضعف در خط مشی گذرواژه قوی	☐	☒	☐
۱۲	ذخیره اطلاعات حساس در مرورگر	☐	☒	☐
۱۳	ضعف در فرایند تغییر/بازیابی اعتبارنامه	☐	☒	☐
۱۴	تکرارپذیری درخواست ها و حملات بروتفورس	☒	☐	☐
۱۵	آسیب پذیری Directory traversal/file include	☐	☒	☐
۱۶	دور زدن مکانیزم های کنترل دسترسی	☒	☐	☐
۱۷	ارجاع ناامن کاربر به یک شی	☒	☐	☐
۱۸	ارتقای سطح دسترسی	☒	☐	☐
۱۹	دور زدن مدیریت نشست	☐	☒	☐
۲۰	ضعف در مشخصه های کوکی	☒	☐	☐
۲۱	تثبیت نشست	☐	☒	☐
۲۲	ضعف در خروج کاربر	☐	☒	☐
۲۳	حمله جعل درخواست (CSRF)	☐	☒	☐
۲۴	حمله XSS	☒	☐	☐
۲۵	الحاق پرونده محلی	☐	☒	☐
۲۶	الحاق پرونده از راه دور	☐	☒	☐
۲۷	جعل محتوا	☐	☐	☒

☐	☒	☐	آسیب‌پذیری سرریز بافر	۲۸	
☐	☒	☐	حملات بارگذاری فایل	۲۹	
☐	☐	☒	سایر حملات تزریق (SQL، LDAP، command و ...)	۳۰	
☐	☒	☐	ضعف در پیاده‌سازی SSL	۳۱	رمزنگاری
☐	☒	☐	عدم انتقال خودکار به کانال ارتباطی امن	۳۲	
☐	☒	☐	عدم پیاده‌سازی کانال ارتباطی امن	۳۳	
☐	☐	☒	سایر آسیب‌پذیری‌ها	۳۴	سایر

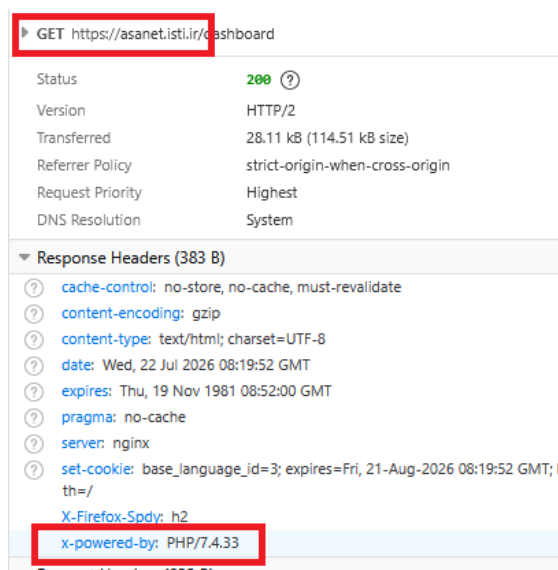
۴ تشریح آسیب‌پذیری‌ها

۴-۱ افشای نسخه PHP

شدت:	کم	امتیاز مبنا:	3.3	بردار:	AV:L/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N
------	----	--------------	-----	--------	-------------------------------------

در بررسی عملی، با ارسال درخواست به سامانه و تحلیل هدرهای پاسخ HTTP، مشاهده گردید اطلاعاتی شامل نسخه دقیق PHP در خروجی قابل مشاهده است. مهاجم می‌تواند با استفاده از این اطلاعات، نسخه مذکور را با پایگاه‌های داده آسیب‌پذیری‌های شناخته‌شده تطبیق داده و در صورت وجود اکسپلویت‌های عمومی، حملات هدفمندتری را طراحی و اجرا نماید.

به عبارت دیگر، این ضعف به مهاجم دید مناسبی از ساختار فناوری سامانه ارائه می‌دهد و می‌تواند به عنوان یک گام اولیه در زنجیره حملات پیچیده‌تر مورد استفاده قرار گیرد.



شکل ۱: افشای نسخه PHP

۴-۱-۱ روش برطرف سازی

جهت رفع این آسیب پذیری، توصیه می شود نمایش اطلاعات مربوط به نسخه PHP در تمامی خروجی های سامانه غیرفعال گردد. این اقدام معمولاً از طریق تنظیمات سرور و فایل پیکربندی PHP (مانند غیرفعال سازی expose_php) قابل انجام است.

همچنین پیشنهاد می شود هدرهای غیرضروری که اطلاعات فنی سامانه را افشا می کنند حذف یا سفارشی سازی شوند. در کنار این موارد، به روزرسانی مستمر نسخه PHP به آخرین نسخه پایدار و اعمال وصله های امنیتی، از اقدامات ضروری برای کاهش ریسک سوءاستفاده از آسیب پذیری های شناخته شده محسوب می شود.

۴-۲ عدم تنظیم ویژگی امنیتی SameSite برای کوکی های نشست

شدت:	متوسط	امتیاز مبنا:	5.5	بردار:	AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:L
------	-------	--------------	-----	--------	-------------------------------------

در جریان ارزیابی امنیتی سامانه، مشخص گردید کوکی های مورد استفاده در مدیریت نشست کاربران فاقد ویژگی امنیتی SameSite می باشند. این ویژگی یکی از مکانیزم های کلیدی در مرورگرها برای کنترل ارسال کوکی ها در درخواست های Cross-Site محسوب می شود و نقش مهمی در کاهش ریسک حملات جعل درخواست بین سایتی (CSRF) ایفا می کند.

بررسی هدرهای پاسخ HTTP نشان داد که کوکی نشست بدون مقداردهی Attribute مربوط به SameSite ایجاد می شود. در نتیجه، مرورگر در شرایط پیش فرض ممکن است کوکی را در درخواست هایی که از دامنه های دیگر به سامانه ارسال می شوند نیز ضمیمه نماید. این رفتار بیانگر آن است که هیچ محدودیتی برای کنترل نحوه ارسال کوکی در سناریوهای Cross-Origin اعمال نشده و سامانه در برابر حملات مبتنی بر سوءاستفاده از نشست کاربر آسیب پذیر است.

Filter Items		Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite
Cache Storage	https://asanetlist.ir	54152b2447df3967931e696dac023...	34m1nds48tpcu39(yipniq4cl	asanetlist.ir	/	Session	58	true	true	
		base_language_id	3	asanetlist.ir	/	Fri, 21 Aug 2026 08:00:08 G...	17	false	false	
Indexed DB		body2		asanetlist.ir	/	Wed, 29 Jul 2026 07:54:16 G...	5	false	false	
		ilijalali	1	asanetlist.ir	/admin/ilisports/pa...	Session	10	false	false	
Session Storage		ilijalali	1	asanetlist.ir	/	Session	10	false	false	
		im_showOnlineOnly	0	asanetlist.ir	/	Mon, 20 Jul 2026 08:04:40 G...	18	false	false	
		ow_login	bc0b6f9d1bdfce41cd358fd45e0...	asanetlist.ir	/	Wed, 29 Jul 2026 07:53:00 G...	40	true	true	

شکل ۳: عدم تنظیم ویژگی SameSite

۴-۲-۱ روش برطرف سازی

برای کاهش ریسک این آسیب پذیری، ضروری است ویژگی SameSite برای تمامی کوکی های حساس، به ویژه کوکی های نشست، به درستی تنظیم شود. در اغلب سناریوها، استفاده از مقدار SameSite=Strict یا حداقل SameSite=Lax توصیه می شود تا از ارسال کوکی در درخواست های Cross-Site جلوگیری یا محدود شود. علاوه بر این، پیاده سازی مکانیزم های مکمل نظیر استفاده از توکن های ضد CSRF (CSRF Tokens) در درخواست های حساس، بررسی هدرهای Origin و Referer، و طراحی صحیح فرآیندهای احراز هویت، از جمله اقدامات ضروری برای افزایش سطح امنیت در برابر حملات جعل درخواست می باشد.

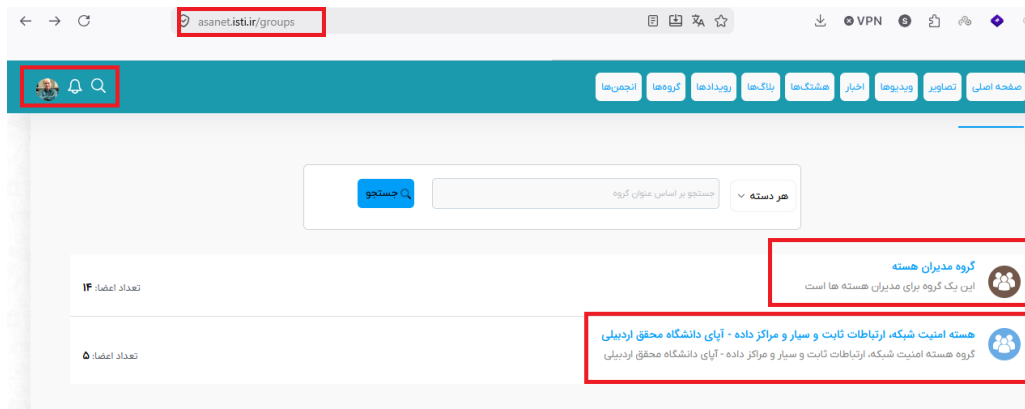
۴-۳ نقص در کنترل دسترسی (IDOR / Broken Access Control)

شدت:	زیاد	امتیاز مبنا:	8.1	بردار:	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
------	------	--------------	-----	--------	-------------------------------------

در جریان ارزیابی امنیتی سامانه، مشخص گردید مکانیزم کنترل دسترسی در بخش مدیریت گروه ها به درستی پیاده سازی نشده است. به صورت پیش فرض، هر کاربر عضو یک گروه خاص، امکان دسترسی به منابع مرتبط با همان گروه از جمله فهرست کاربران، فایل های بارگذاری شده و پیام های رد و بدل شده را دارد که این رفتار مطابق با منطق سامانه می باشد. با این حال، بررسی دقیق تر نشان داد که شناسه گروه (Group ID) در پارامترهای URL به عنوان مبنای تعیین سطح دسترسی مورد استفاده قرار می گیرد، بدون آنکه اعتبارسنجی سمت سرور جهت اطمینان از تعلق کاربر به گروه مورد نظر انجام شود.

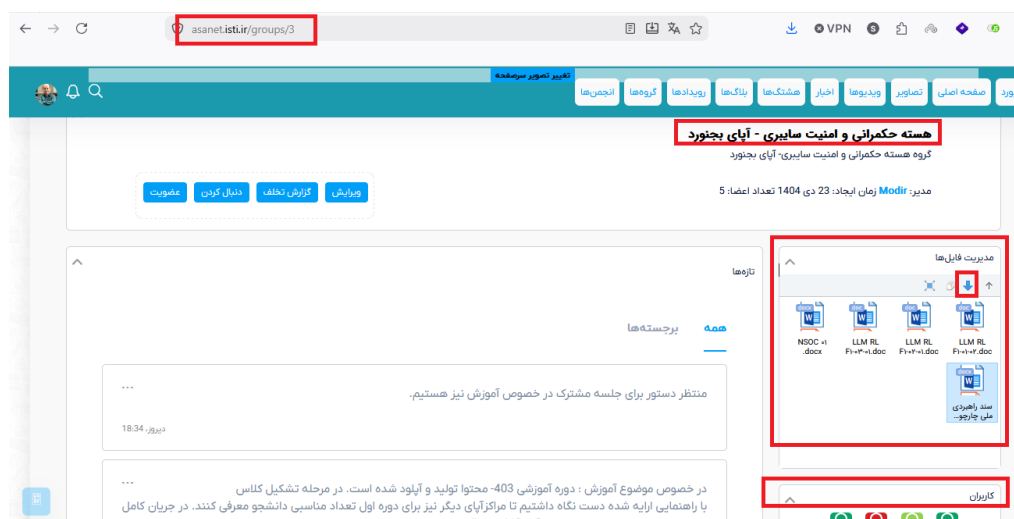
این موضوع منجر به بروز یک نقص جدی در کنترل دسترسی شده است، به گونه ای که کاربر می تواند صرفاً با تغییر مقدار شناسه گروه در URL، به منابع سایر گروه ها نیز دسترسی پیدا کند. این رفتار نشان دهنده عدم اعمال کنترل های دسترسی مبتنی بر هویت (Authorization) در سمت سرور و وابستگی بیش از حد به داده های سمت کاربر است.

به منظور بررسی عملی، کاربر دارای دسترسی به یک گروه مشخص، اقدام به تغییر شناسه گروه در درخواست های ارسالی نمود. نتایج نشان داد که بدون نیاز به هیچ گونه مجوز اضافی، دسترسی به اطلاعات گروه های دیگر نیز فراهم می شود. این دسترسی شامل مشاهده لیست کاربران آن گروه، دریافت فایل های بارگذاری شده و حتی مشاهده و در برخی موارد ویرایش پیام های بین اعضای گروه های دیگر بوده است. در شکل ۳ میتوان دید که کاربر احراز هویت شده دسترسی به دو گروه با نام های مشخص در تصویر دارد.



شکل ۳: لیست گروه های کاربر احراز هویت شده

اما با تغییر id در مسیر URL امکان دسترسی به اطلاعات گروه های دیگر را نیز دارد که در تصویر ۴ این دسترسی را میتوان دید..



شکل ۴: دسترسی به اطلاعات دیگر گروه ها

۴-۳-۱ روش برطرف سازی

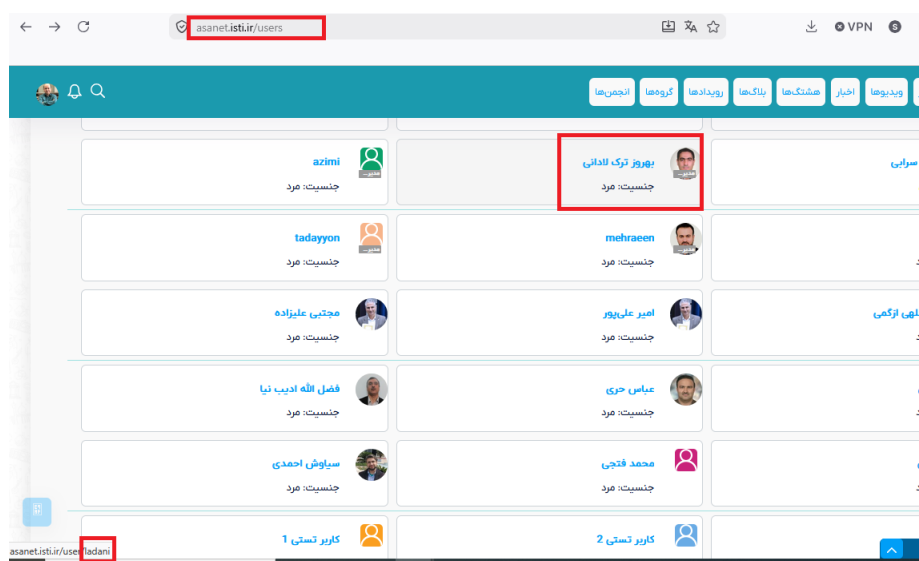
برای رفع این آسیب پذیری، ضروری است کنترل دسترسی به صورت کامل در سمت سرور و مستقل از ورودی کاربر پیاده سازی شود. به این معنا که برای هر درخواست، سامانه باید به طور صریح بررسی نماید که کاربر احراز هویت شده، مجاز به دسترسی به منبع مورد نظر (گروه) هست یا خیر. استفاده از مکانیزم های استاندارد Authorization، پیاده سازی بررسی های مبتنی بر نقش و مالکیت (RBAC/ABAC)، و عدم اعتماد به پارامترهای دریافتی از سمت کاربر از جمله اقدامات کلیدی در این زمینه است.

همچنین توصیه می‌شود شناسه‌های قابل حدس (Sequential IDs) با شناسه‌های غیرقابل پیش‌بینی (مانند UUID) جایگزین شده و تمامی دسترسی‌ها به منابع حساس ثبت و مانیتور شوند تا در صورت بروز رفتار مشکوک، امکان شناسایی و واکنش سریع فراهم گردد.

۴-۴ حمله Brute Force در فرآیند احراز هویت

شدت:	زیاد	امتیاز مینا:	7.5	بردار:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
------	------	--------------	-----	--------	-------------------------------------

ارزیابی فرآیند احراز هویت نشان داد که سامانه فاقد کنترل‌های لازم برای مقابله با تلاش‌های مکرر ورود ناموفق است. به عبارت دیگر، هیچ محدودیت مؤثری بر تعداد دفعات تلاش برای ورود اعمال نشده و مکانیزم‌هایی نظیر قفل موقت حساب کاربری یا محدودسازی نرخ درخواست‌ها در نظر گرفته نشده است. از سوی دیگر، دسترسی کاربران با سطوح مختلف به لیست کاربران سامانه موجب شده نام‌های کاربری معتبر به سادگی در دسترس قرار گیرد (شکل ۵). این ترکیب از ضعف‌ها، شرایطی را فراهم می‌کند که مهاجم بتواند با آگاهی از نام‌های کاربری، حملات حدس رمز عبور را با احتمال موفقیت بالاتری انجام دهد.



شکل ۵: افشای نام کاربری کاربران

در تست عملی، تعداد زیادی درخواست ورود با رمزهای عبور مختلف برای یک یا چند حساب کاربری ارسال شد. رفتار سامانه نشان داد که این درخواست‌ها بدون هیچ‌گونه محدودیت یا واکنش بازدارنده پردازش می‌شوند و حتی پس از تعداد بالای تلاش ناموفق، حساب کاربری همچنان فعال باقی می‌ماند. شکل ۶ امکان بررسی چندین رمز عبور بدون مشکل را نشان می‌دهد.

3. Intruder attack of https://asanet.isti.ir

Results Positions

Intruder attack results filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
583	apaTest1	301	1153			656	
582	NP	301	1142			398	
581	NEWS	301	1142			398	
580	NEWINGRES	301	1144			398	
579	NETWORK	301	1146			398	
578	NETSERVER	301	1146			398	
577	NETPRIV	301	1154			398	
576	NETNONPRIV	301	1162			398	

Request Response

Pretty Raw Hex Render

```

1 HTTP/2 301 Moved Permanently
2 Server: nginx
3 Date: Sun, 19 Jul 2026 08:48:52 GMT
4 Content-Type: text/html; charset=UTF-8
5 Location: https://asanet.isti.ir/signin
6 X-Powered-By: PHP/7.4.33
7 Expires: Thu, 19 Nov 1981 08:52:00 GMT
8 Cache-Control: no-store, no-cache, must-revalidate
9 Pragma: no-cache
Set-Cookie: base_language_id=3; expires=Tue, 18-Aug-2026 08:48:51 GMT; Max-Age=2592000; path=/
Set-Cookie: 54152b2447df3567591e696dac0c3862-cc8bno7q4n4r13u4e5ts3phsqa; path=/; secure; HttpOnly
Set-Cookie: ow_login=7e4743acb2b52b5d44972c1b6df51452; expires=Sun, 26-Jul-2026 08:48:52 GMT; Max-Age=604800; path=/; domain=asanet.isti.ir; secure; HttpOnly

```

شکل ۶: بررسی رمز عبورهای مختلف و دستیابی به رمز عبور کاربر

این موضوع اثبات می‌کند که مهاجم می‌تواند با استفاده از ابزارهای خودکار، فرآیند آزمون و خطا را تا دستیابی به رمز صحیح ادامه دهد و در نهایت کنترل حساب کاربری را به دست گیرد.

۴-۴-۱ روش برطرف سازی

برای کاهش ریسک این آسیب‌پذیری، پیاده‌سازی مکانیزم‌های کنترلی در فرآیند احراز هویت ضروری است. این اقدامات باید شامل محدودسازی نرخ درخواست‌های ورود، اعمال قفل موقت حساب پس از چند تلاش ناموفق، و استفاده از مکانیزم‌های تکمیلی نظیر CAPTCHA یا احراز هویت چندعاملی باشد. همچنین توصیه می‌شود دسترسی به اطلاعات کاربران، به‌ویژه لیست نام‌های کاربری، بر اساس اصل حداقل دسترسی (Least Privilege) محدود شده و از افشای غیرضروری این اطلاعات جلوگیری گردد.

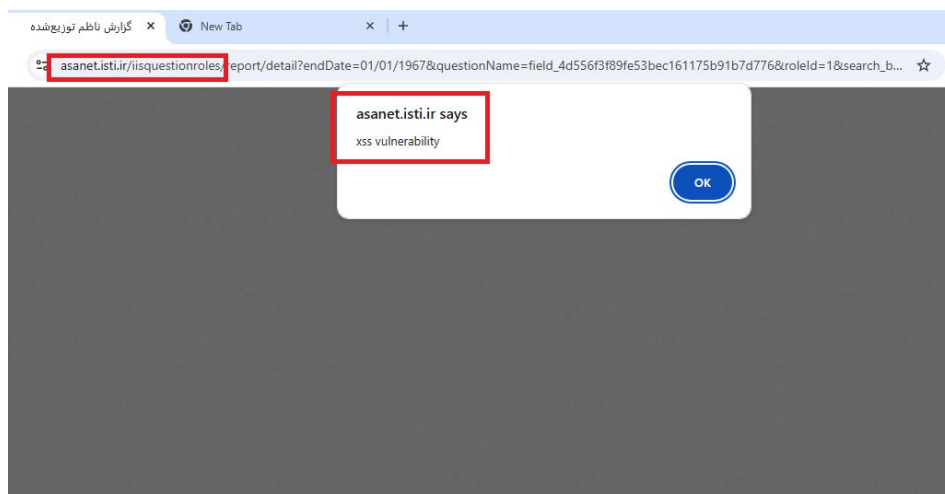
۴-۵ Cross-Site Scripting از نوع Reflected

شدت:	زیاد	امتیاز مبنا:	8.2	بردار:	AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:L
------	------	--------------	-----	--------	-------------------------------------

در بررسی انجام‌شده بر روی مسیر `iisquestionroles/report/detail/` مشخص گردید پارامتر `endDate` بدون اعمال مکانیزم‌های مناسب کدگذاری خروجی، مستقیماً در پاسخ HTML صفحه بازتاب داده می‌شود. این موضوع نشان‌دهنده عدم پیاده‌سازی صحیح کنترل‌های امنیتی در لایه ارائه بوده و باعث می‌شود ورودی کاربر به‌عنوان کد قابل اجرا در مرورگر تفسیر گردد. ماهیت این ضعف، از نوع Reflected XSS بوده و به‌طور مستقیم به نحوه پردازش و نمایش داده‌های ورودی وابسته است.

همانطور که در تصویر زیر نیز میتوان دید در سناریوی تست، مقدار پارامتر `endDate` با یک `payload` جاوااسکریپت جایگزین گردید و درخواست به سامانه ارسال شد. پاسخ دریافتی نشان داد که مقدار تزریق‌شده

بدون تغییر در صفحه بازتاب یافته و کد جاوااسکریپت در مرورگر اجرا می‌شود. این رفتار بیانگر آن است که مهاجم می‌تواند با ارسال یک لینک دستکاری‌شده به کاربران، کد مخرب خود را در بستر دامنه سامانه اجرا نموده و به اطلاعات حساس نظیر کوکی‌های نشست یا محتوای صفحه دسترسی پیدا کند.



شکل ۷: اثبات آسیب‌پذیری XSS با پیلود ساده

۴-۵-۱ روش برطرف‌سازی

برای رفع این آسیب‌پذیری، لازم است تمامی داده‌های ورودی پیش از نمایش در خروجی، بر اساس کانتکست مربوطه به‌درستی Encode شوند. استفاده از مکانیزم‌های استاندارد Output Encoding در HTML، جلوگیری از درج مستقیم داده‌های کاربر در DOM، و بهره‌گیری از سیاست‌های امنیتی مرورگر نظیر Content Security Policy (CSP) از جمله اقدامات مؤثر در این زمینه است. همچنین توصیه می‌شود اعتبارسنجی ورودی‌ها در سمت سرور به‌صورت سخت‌گیرانه انجام شود.

۶-۴ تزریق SQL در پارامتر photos

شدت:	بحرانی	امتیاز مبنا:	9.8	بردار:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
------	--------	--------------	-----	--------	-------------------------------------

در جریان ارزیابی امنیتی سامانه، مشخص گردید در مسیر /photo/photo/ajax-responder/ یک درخواست با متد POST دریافت می‌شود که پارامتر photos در آن بدون اعمال کنترل‌های لازم مورد پردازش قرار می‌گیرد. بررسی رفتار سامانه نشان داد که ورودی این پارامتر مستقیماً در کوئری‌های پایگاه داده مورد استفاده قرار می‌گیرد، بدون آنکه اعتبارسنجی مناسب یا مکانیزم‌های ایمن‌سازی نظیر استفاده از کوئری‌های پارامتری (Parameterized Queries) بر روی آن اعمال شده باشد. این وضعیت منجر به امکان تزریق دستورات SQL از طریق ورودی کاربر می‌گردد و نشان‌دهنده ضعف در لایه تعامل با پایگاه داده است.

به منظور ارزیابی عملی، مقادیر دستکاری شده حاوی عبارات SQL به پارامتر photos[] تزریق گردید. نتایج نشان داد پاسخ سامانه در مواجهه با این ورودی‌ها دچار تغییر شده و در برخی موارد خطاهای پایگاه داده یا پاسخ‌های غیرمنتظره بازگردانده می‌شود که بیانگر تفسیر ورودی به عنوان بخشی از دستور SQL است. این رفتار اثبات می‌کند که مهاجم قادر خواهد بود با ساخت payloadهای هدفمند، به استخراج داده‌ها، دور زدن محدودیت‌ها و حتی در شرایط خاص، تغییر یا حذف اطلاعات دست یابد. همانطور که در دو تصویر زیر میتوان دید به دلیل آسیب پذیری امکان دسترسی به همه داده های موجود در پایگاه داده ممکن هست من باب اثبات ادعا به شناسایی نام پایگاه داده اکتفا شده است.

```

---
Parameter: photos[] (POST)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: ajaxFunc=getFloatbox&layout=floatbox&listType=latest&loadNextList=1&loadNextPhoto=1&loadPrevList=1&loadPrevPhoto=1&photoId=4&photos[]=4 AND (SELECT 3508 FROM (SELECT(SLEEP(5)))meGq)
---
[15:07:54] [INFO] the back-end DBMS is MySQL
web application technology: Nginx, PHP 7.4.33
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[15:07:54] [INFO] fetching current database
you provided a HTTP Cookie header value, while target URL provides its own cookies within HTTP Set-Cookie header which intersect with yours. Do you want to merge them in further requests? [Y/n] Y
..... (done)
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n] Y
[15:08:20] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptions
[15:08:31] [INFO] adjusting time delay to 4 seconds due to good response times
shub_db
current database: 'shub_db'
[15:10:30] [INFO] fetched data logged to text files under 'C:\Users\ASUS\AppData\Local\sqlmap\output' asanet.isti.ir'
[15:10:30] [WARNING] your sqlmap version is outdated
[*] ending @ 15:10:30 /2026-07-14/

```

شکل ۸: اثبات وجود آسیب پذیری SQL Injection

```

[15:07:10] [INFO] fetched data logged to text files under 'C:\Users\ASUS\AppData\Local\sqlmap\output' asanet.isti.ir'
available databases [4]:
[*] information_schema
[*] mysql
[*] performance_schema
[*] shub_db
[15:31:00] [INFO] fetched data logged to text files under 'C:\Users\ASUS\AppData\Local\sqlmap\output' asanet.isti.ir'
[15:31:00] [WARNING] your sqlmap version is outdated
[*] ending @ 15:31:00 /2026-07-14/
C:\Users\ASUS\Downloads\sqlmap-master\sqlmap-master>

```

شکل ۹: لیست پایگاه داده ها

۴-۶-۱ روش برطرف سازی

جهت رفع این آسیب پذیری، لازم است تمامی تعاملات با پایگاه داده صرفاً از طریق کوئری‌های پارامتری یا ORMهای امن انجام شود تا امکان تفسیر ورودی به عنوان کد SQL از بین برود. علاوه بر این، اعتبارسنجی دقیق داده‌های ورودی بر اساس نوع و ساختار مورد انتظار، استفاده از لیست سفید (Whitelist Validation) و غیرفعال سازی نمایش خطاهای پایگاه داده در خروجی به کاربران، از اقدامات ضروری در کاهش ریسک این آسیب پذیری محسوب می‌شود.

۵ اطلاعات تماس تیم تست

ردیف	نام و نام خانوادگی	شماره تماس
۱	دکتر شهرام جمالی	۰۹۱۴۴۵۱۴۳۴۰
۲	مهندس سحر علیزاده	۰۹۱۴۶۱۸۳۱۷۸